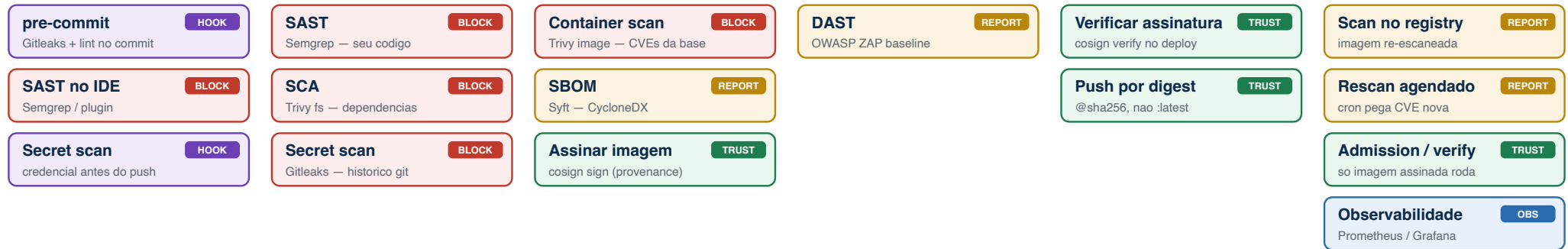


DevSecOps no pipeline CI/CD — controle por estagio

Onde cada verificacao roda, com o toolset real — e o que o video nao mostra: assinatura de imagem e runtime

SHIFT LEFT — detectar o mais cedo possivel



CI / CD PIPELINE

Legenda dos gates

- BLOCK** barra o merge/deploy (codigo, deps, secrets, CRITICAL c/ fix)
- REPORT** so reporta ate haver triagem (DAST, SBOM, scan de runtime)
- TRUST** cadeia de confianca — o que o video nao cobre
- HOOK** roda local, antes de existir commit
- OBS** observabilidade em producao

3 pontos que a banca vai cobrar

- Checagens estaticas (SAST/SCA/secrets) rodam em 3 estagios: IDE + Source + Build — nao uma vez so.
- Scan diz 'a imagem esta limpa'. Assinatura (cosign) diz 'e a mesma que eu construi' — sao coisas diferentes.
- Tag e movel e pode ser reescrita; digest @sha256 nao. Deploy por digest, nunca :latest.
- SBOM: exigencia do FDA para software de dispositivo medico desde 2023 — nao so boa pratica.
- Distrosless nem sempre ganha: medi 49 CVEs (2 CRITICAL) vs slim endurecido 44 (0). Medir > supor.